

작성일 2026-09-18. 58개 문항 회신. 코드에서 확인되는 동작과 기업 확인 사항을 구분했습니다. 별첨은 SOH_DID_기술설명서.pdf를 뜻합니다.

□ 작성 안내

○ 해당 업무를 수행하는 인력이나 절차가 없는 경우 해당 없음으로 회신하면 된다. 그 자체가 점검 결과로 반영된다.

○ 제출 자료에 이미 기재된 내용은 자료명과 위치를 적는 것으로 같음할 수 있다.

※ 총 58개 문항이며 각 분류의 괄호 안은 대응하는 사전 요청자료 번호다.

□ 1. 설계 의도와 전제

No.	질의 항목	회신
1	온체인에 둔 데이터와 오프체인에 둔 데이터를 나눈 기준은 무엇입니까.	코드상 계정·토큰 거래는 DChain으로 요청하고 DID 문서·키·사용자 지급 상태·토큰 메타데이터는 파일/DB에 둡니다. DID 자체는 로컬 did:key이며 체인 등록과 다릅니다. 설계 당시 분류 기준은 담당자 확인 필요. [별첨 A2]
2	설계 시 신뢰할 수 있다고 전제한 주체는 누구입니까. 그 주체가 악의적으로 행동하면 어떤 결과가 발생합니까.	DChain API, Flask 실행환경, 로컬 키 파일 및 MySQL을 신뢰하는 구조입니다. 이들이 침해되면 거래 요청·서명키·지급 상태가 변조될 수 있습니다. 공식 신뢰 가정·통제는 확인 필요. [별첨 A3·C]
3	시스템 전체에서 항상 참이어야 하는 조건은 무엇입니까. 그 조건이 깨진 것을 무엇으로 알 수 있습니까.	공식 불변식은 미확인입니다. 구현은 일부 DB 갱신에 HTTP 200 및 state=OK를 요구하지만 온체인 잔액과 DB 상태의 일치를 보장하지 않습니다. 독립 대사·불변식 감시 로직은 미확인. [별첨 B2·D1]
4	주요 파라미터의 현재 값을 그 값으로 정한 근거는 무엇입니까.	기본값은 chain=minic, DChain timeout 20초, token decimals 9, VC TTL 3600초, VP TTL 300초입니다. 운영값과 값 선정 근거는 별도 확인 필요. [별첨 D1]
5	파라미터가 어떤 범위를 벗어나면 위험하다고 판단합니까. 그 범위를 코드에서 강제하고 있습니까.	전송 token_name은 허용된 영상 토큰 12종으로 제한합니다. amount의 양수·상한과 TTL의 양수·상한에 대한 공통 검사는 미확인입니다. 업무상 위험 임계값은 기업

No.	질의 항목	회신
		확인 필요. [별첨 D1]
6	산술 계산에서 반올림 방향과 정밀도를 어떻게 정했습니까. 절삭으로 남는 잔여분은 어디로 귀속됩니까.	토큰 생성 decimals 기본값은 9이며 체인 계산은 외부 API에 의존합니다. 백엔드 지급 상태는 수량을 누적하지 않고 1로 기록합니다. 온체인 반올림 · 잔여분 귀속 정책은 운영기관 확인 필요. [USER_db.py]
7	수수료, 이자, 보상 산정식은 문서와 코드 중 무엇을 기준으로 관리합니까. 둘이 다를 경우 무엇이 우선합니까.	영상 토큰 지급 경로에 amount 기본값 1이 있습니다. 수수료 · 이자 · 보상 산정 공식 및 문서/코드 우선순위 정책은 저장소에서 미확인입니다. 서비스 담당자 확인 필요.

□ 2. 스마트 컨트랙트와 배포

No.	질의 항목	회신
8	점검 대상으로 지정한 시점 이후 배포 전까지 코드 변경 계획이 있습니까.	이번 문서 기준 소스는 9f31eee입니다. 이번 작업은 문서만 작성하며 이후 배포 전 코드 변경 계획은 개발·배포 담당자가 확정해야 합니다.
9	외부 저장소에서 가져와 수정한 코드가 있습니까. 있다면 원본 대비 무엇을 바꾸었고 그 이유는 무엇입니까.	PyMySQL 1.1.1 vendor 포함은 확인됩니다. 자체 컨트랙트 fork 원본·버전·변경 내역은 미확인입니다. 오픈소스 구성과 수정 이력은 개발 담당자 확인 필요.
10	배포 시 초기 파라미터를 누가 정하고 누가 검증합니까.	환경변수와 일부 코드 기본값으로 초기값을 설정합니다. 값을 정하는 직무, 독립 검증자와 승인 기록은 미확인입니다. 자체 컨트랙트 배포 절차 적용 여부도 확인 필요.
11	배포 직후 수행하는 검증 절차가 있습니까. 무엇을 확인합니까.	회수 API 테스트 코드와 EC2 서비스 예시는 있습니다. 실제 배포 직후 점검 목록, 실행 기록 및 승인 기준은 미확인입니다. 테스트 코드를 배포 검증 완료 증적으로 간주하지 않습니다.
12	배포가 잘못되었을 때 되돌리는 방법은 무엇입니까.	배포 롤백 및 온체인 거래 보상 절차는 미확인입니다. DID DB 저장 rollback은 이미 생성된 체인 지갑·파일을 취소하지 않습니다. 코드 롤백과 자산 복구는 구분해 확인해야 합니다.
13	테스트가 다루지 못한다고 이미 알고 있는 영역이 있습니까.	회수 테스트 코드만 정적으로 검토했으며 이번엔 실행하지 않았습니다. 운영 체인·DB, 외부 서명, 장애 후 보상, 다중 프로세스 파일 경합의 검증 기록은 미확인입니다. 기업이 인지한 미검증 범위는 별도 확인 필요.

□ 3. 권한과 업그레이드

No.	질의 항목	회신
14	배포 이후에도 남아 있는 특권 권한은 무엇이며 남겨 둔 이유는 무엇입니까.	서버 소유자 설정은 토큰 생성·mint 및 전송 기본값, 회수 권한 비교에 쓰입니다. 실제 온체인 권한과 유지 사유는 확인 필요합니다. 공통 호출자 인증·역할 통제는 라우트에서 미확인. [서식6]
15	다중서명 임계값을 현재 값으로 정한 근거는 무엇입니까.	다중서명 구현과 임계값은 저장소에서 미확인입니다. 체인 또는 별도 운영 솔루션의 적용 여부 및 근거를 확인해야 하며 임계

No.	질의 항목	회신
		값을 임의로 기재하지 않습니다.
16	서명자 중 몇 명이 동시에 연락 두절되면 운영이 멈추니까.	서명자 직무·인원·다중서명 임계값이 미확인이라 중단 인원을 산정할 수 없습니다. 서버 키 의존 경로는 있으나 운영 대체 담당·복구 가능성은 별도 확인 필요.
17	서명자 키가 서로 다른 매체와 장소에 보관되어 있습니까. 한 사람이 둘 이상의 키를 보관하는 경우가 있습니까.	DID 키는 파일과 DB, 사용자 체인 키는 로컬 키 파일, 소유자 키는 서버 설정에 사용됩니다. 서명자별 매체·장소 분리 및 1인 복수 키 보관 여부는 기업 확인 필요.
18	타임락을 설정했다면 그 시간 동안 무엇을 하기로 되어 있습니까. 실제로 그 절차를 수행한 적이 있습니까.	타임락 설정 및 대기 중 검증·취소 절차와 수행 기록은 저장소에서 미확인입니다. 외부 체인 설정과 별도 운영 절차의 존재 여부를 확인해야 합니다.
19	권한 보유자가 퇴사하거나 직무가 바뀔 때 권한 회수는 어떤 절차로 이루어집니까.	퇴사·직무 변경 시 권한 회수 절차와 이력은 기업 확인 필요합니다. /did/delete는 파일과 인덱스를 삭제하며 DID/user DB 행·백업·기전달 키 회수까지 수행하지 않습니다.
20	업그레이드 시 스토리지 배치 충돌을 어떤 방법으로 확인합니까.	자체 업그레이드 컨트랙트·스토리지 레이아웃과 충돌 검사 도구는 미확인입니다. 적용 구조를 확인한 후 배포 담당자가 검증 방법·기록을 제출해야 합니다.
21	긴급 상황에서 정해진 절차를 생략하고 업그레이드할 수 있는 경로가 있습니까.	정상·긴급 업그레이드 절차와 우회 실행 경로는 미확인입니다. 별도 컨트랙트 관리자·배포 계정의 실제 권한 및 비상 승인 체계 확인이 필요합니다.

□ 4. 외부 의존성

No.	질의 항목	회신
22	각 외부 대상이 잘못된 값을 반환하면 시스템에서 어떤 결과가 발생합니까.	DChain 오류 값은 계정 주소 · 토큰 메타데이터 · 거래 성공 판정에 영향을 줍니다. MySQL 불일치는 주소 조회 · 지급 상태에, 키 파일 오류는 서명 · 회수에 영향을 줍니다. 운영 주체는 DChain 제공기관 및 기업 운영 담당 확인 필요. [별첨 A3]
23	외부 대상의 값이 정상 범위를 벗어났는지 검증하는 로직이 있습니까.	DID 계정 생성에서 주소 존재 여부, 일부 거래 후 HTTP 200/state=OK 및 token_name 허용 목록을 검사합니다. 외부 가격 · 잔액 · 금액 전반의 범위 및 독립 검증은 미확인입니다.
24	외부 대상이 응답하지 않을 때 시스템은 멈추니까, 아니면 마지막 값을 계속 사용합니까.	기본 20초 timeout 시 504, 연결 · 요청 오류 시 502를 반환합니다. 마지막 성공값으로 거래를 계속하는 fallback, 대체 RPC 또는 재시도 큐는 미확인입니다. DB는 연결 재확인 · 재접속을 시도합니다.
25	외부 대상의 운영 주체가 값을 임의로 바꿀 수 있습니까. 그 경우 대응 수단이 있습니까.	외부 운영기관의 값 변경 권한과 운영 통제는 본 저장소로 검증할 수 없습니다. 독립 노드 대조 · 응답 무결성 검증 · 공급사 대응 약정은 기업 및 제공기관 확인 필요.
26	브릿지를 사용한다면 양쪽 체인의 자산 수량이 일치하는지 무엇으로 확인합니까.	브릿지 연계 구현은 이 저장소에서 미확인입니다. 서비스 전체의 사용 여부를 확인한 후 미사용이면 해당 없음으로 확정하며, 사용 시 양 체인 대사 자료가 필요합니다.

□ 5. 노드와 체인 운영

No.	질의 항목	회신
27	노드의 RPC 를 외부에 공개하고 있습니까. 공개한다면 어떤 메서드까지 허용합니까.	외부 DChain HTTPS API를 호출합니다. 자체 노드 RPC 공개 설정은 미확인입니다. 앱에는 조회 및 자산 변경 프록시가 있으므로 운영 URL · 인증 · 네트워크 허용 범위는 별도 확인 필요.
28	트랜잭션을 몇 블록 확정 후 최종으로 인정합니까. 그 수를 정한 근거는 무엇입니까.	일부 거래 성공은 HTTP 200/state=OK로 판단합니다. 독립적인 확정 블록 수 기준은 미확인입니다. DChain 응답의 최종성 의미와 운영 기준을 제공기관에 확인해야 합니다.
29	체인 재구성이 발생한 경우 어떻게 인지하고 무엇을 되돌립니까.	체인 재구성 감지, 입금 상태 롤백 및 재처리 로직은 저장소에서 미확인입니다. 외부

No.	질의 항목	회신
		체인의 최종성과 서비스의 대응 책임·절차를 확인해야 합니다.
30	노드 클라이언트 버전 업그레이드와 하드포크 대응은 누가 판단하고 언제 적용합니까.	노드 직접 운영 여부와 클라이언트 버전은 미확인입니다. 노드 업그레이드·하드포크 판단 주체, 일정 및 검증 기준은 기업/체인 운영기관 확인 필요.
31	허가형 체인을 운영한다면 채널 또는 조직을 추가하거나 제거하는 결정은 누가 승인합니까.	체인 유형과 직접 운영 범위가 확정되지 않았습니다. 허가형 채널·조직 변경 설정 및 승인자는 미확인이므로 적용 여부부터 확인해야 합니다.
32	허가형 체인을 운영한다면 인증서 폐기가 필요할 때 어떤 절차로 처리합니까.	허가형 체인의 CA/MSP 및 인증서 폐기 절차는 미확인입니다. 로컬 did:key 파일 삭제는 체인 인증서 폐기 절차를 대신하지 않습니다.

□ 6. 키 관리와 서명 통제

No.	질의 항목	회신
33	키를 생성할 때 사용한 난수 원천은 무엇입니까. 생성 과정을 기록으로 남겼습니까.	DID 키는 cryptography의 <code>Ed25519PrivateKey.generate()</code> 로 생성해 라이브러리에 난수 생성을 위임합니다. 체인 키는 DChain 계정 생성 응답으로 받습니다. 입회·생성 기록·외부 난수 원천은 미확인.
34	키가 평문으로 존재하는 순간이 있습니까. 있다면 어디입니까.	키는 Flask 메모리, 로컬 JSON 및 DID 개인키 DB 필드에 평문으로 존재합니다. DID 생성 응답에는 개인키와 wallet 객체가 포함되고 체인 요청에 키를 전달합니다. 테스트 웹 출력에도 노출 가능. [별첨 C2]
35	개발자 개인 단말에 배포용 키가 남아 있는 경우가 있습니까.	소유자 키 등의 민감 기본값이 소스에 포함됩니다. 개발자 단말·배포본·이력·백업에 남은 사본 여부는 기업 확인 필요합니다. 본 제출 문서에는 비밀값을 수록하지 않았습니다.
36	키 백업본은 몇 부가 어디에 있으며 누가 접근할 수 있습니까.	키 백업본의 수량, 장소, 접근 직무·인원과 분산 보관 절차는 저장소에서 미확인입니다. 실제 백업 자산 목록과 접근 기록을 기업이 확인해야 합니다.
37	복구 절차를 실제로 시험해 본 적이 있습니까. 언제 수행했고 결과는 어땠습니까.	키 복구 시험 일자·절차·결과 증적은 미확인입니다. 기업 보유 시험 보고서와 복구 담당자 확인이 필요하며 미실시로 단정하지 않습니다.
38	키를 교체한 적이 있습니까. 교체 시 기존 키는 어떻게 처리합니까.	교체 이력·주기·폐기 정책은 기업 확인 필요합니다. <code>/did/delete</code> 는 파일 unlink와 인덱스 삭제만 수행하고 DB 및 백업의 키 폐기·매체 완전삭제는 수행하지 않습니다.
39	서명 요청이 정당한지 누가 어떻게 확인합니까. 요청자와 승인자가 분리되어 있습니까.	<code>/token/retrieve</code> 는 송수신 주소와 소유자 키를 비교합니다. 이는 사람의 분리 승인·MFA가 아닙니다. 공통 요청자/승인자 분리와 역할 인증은 미확인입니다. 직접 <code>transfer_from</code> 에는 이 비교가 적용되지 않습니다.
40	서명 대상 데이터를 서명 화면과 다른 경로로 대조하는 절차가 있습니까.	테스트 웹은 응답을 화면·콘솔에 출력합니다. 독립 채널에서 금액·목적지·서명 데이터를 대조하는 절차와 전용 서명 화면은 미확인입니다. 운영 절차 확인 필요.
41	화이트리스트에 없는 주소로 출금해야 할 때 어떤 절차를 거칩니까. 실제 사례가 있습니까.	일반 출금 주소 화이트리스트와 예외 승인 절차·실제 사례는 미확인입니다. <code>retrieve</code> 의 소유자 주소 비교를 서비스 전반의 출금 화이트리스트로 보지 않습니다.
42	키가 유출되었다고 판단하는 기준은	키 유출 판단 기준, 첫 조치, 담당 직무와

No.	질의 항목	회신
	무엇입니까. 판단 후 첫 조치는 무엇이며 몇 분 안에 가능합니까.	대응 시간은 기업 확인 필요합니다. 긴급 자산 이전 · 키 교체 · 연락망 및 훈련 증적은 저장소에서 미확인입니다.

□ 7. 온체인 연계 백엔드와 관리자 콘솔

No.	질의 항목	회신
43	출금 트랜잭션을 발생시킬 수 있는 경로를 전부 나열하면 무엇입니까.	자산 이동 요청: /token/transfer, /token/transfer_from, /token/retrieve, /common/cur_transfer. 승인 · 공급 변경: token/create · approve · mint · burn. acc_create · acc_faucet · DID 생성 · upload_token도 체인 변경 여부 확인 대상입니다. [별첨 B4]
44	정상 경로 외에 운영자 수동 실행이나 배치 작업으로 출금이 발생하는 경우가 있습니까.	공개된 프록시 API를 직접 호출할 수 있는 경로는 있습니다. 운영자 수동 호출, 별도 배치 · 관리 도구의 존재와 권한은 저장소만으로 확인할 수 없어 추가 확인 필요합니다.
45	같은 출금 요청이 두 번 처리되는 것을 무엇으로 막습니까.	출금 요청 식별자에 의한 멍등성 · 중복 거래 차단은 해당 라우트에서 미확인입니다. DB 상태를 1로 덮어쓰는 동작은 반복 온체인 전송 자체를 방지하지 않습니다.
46	입금을 확정으로 인정하는 기준은 무엇입니까. 확정 전에 사용자에게 잔액을 반영합니까.	입금 watcher, 확정 대기 · 반영 및 재구성 롤백 로직은 미확인입니다. 잔액 조회 API는 있으나 내부 user 필드는 지급 상태입니다. 실제 입금 확정 및 선반영 정책은 기업 확인 필요.
47	서명 서버에 접근할 수 있는 계정은 몇 개이며 누구입니까. 사람이 직접 접속할 수 있습니까.	VC/VP는 Flask 프로세스에서 서명하고 체인 키는 외부 DChain API로 전달합니다. 전용 서명 서버 구성, 접근 계정 수 · 직무 및 사람의 직접 접속 가능 여부는 미확인입니다.
48	서명 서버가 서명 요청을 거부하는 조건이 있습니까.	retrieve 주소/키 불일치 시 403, 전송의 잘못된 token_name은 400, 미등록 DID는 404, 계약 조회 실패는 400입니다. 레거시 approve 실패 시 회수 전송을 중단합니다. 외부 서명 서버 거부 정책은 확인 필요.
49	관리자 콘솔에서 블록체인 관련 기능을 실행할 때 추가 승인을 요구합니까.	별도 관리자 콘솔 및 추가 승인 · MFA 흐름은 저장소에서 미확인입니다. 테스트 웹을 운영 관리자 콘솔로 단정하지 않으며 실제 관리자 계정 · 기능별 승인은 기업 확인 필요.

□ 8. 이용자 대상 구간

No.	질의 항목	회신
50	프론트엔드와 앱에 들어가는 컨트랙트 주소와 RPC 엔드포인트를 누가 어떤 절차로 변경합니까.	테스트 웹은 로컬 API 주소를 사용하고 서버의 DCHAIN 환경 설정 및 토큰 DB가 연계 값에 관여합니다. 변경 직무·검토·승인·배포 절차는 미확인입니다. [별첨 D2]
51	사용자에게 서명을 요청할 때 승인 범위를 어떻게 표시합니까. 무제한 승인을 요청하는 경우가 있습니까.	사용자 서명 승인 화면은 미확인입니다. 레거시 회수 내부 approve는 요청 수량으로 호출하며 일반 /token/approve는 프록시입니다. 서비스 전체의 무제한 승인 요청 여부는 별도 확인 필요.

□ 9. 모니터링과 긴급 대응

No.	질의 항목	회신
52	특권 함수가 호출되면 몇 분 안에 인지할 수 있습니까. 야간과 휴일에도 동일합니까.	파일 로그는 있으나 특권 함수 감시·알림 및 야간/휴일 관제 증적은 미확인입니다. 인지 시간과 24x7 대응 수준은 기업 확인 필요합니다.
53	출금을 즉시 중지할 권한을 가진 사람은 누구이며 중지까지 몇 분이 걸립니까.	전용 출금 중지 스위치와 컨트랙트 pause 연계는 미확인입니다. OS 서비스 중지 권한자·승인·소요 시간은 확인 필요하며 앱 중지가 이미 제출된 체인 거래를 취소하지는 않습니다.
54	이상 징후 임계값을 정한 근거는 무엇입니까. 오탐이 많아 알람을 끈 사례가 있습니까.	이상 징후 룰·임계값·설정 근거와 오탐으로 알람을 끈 사례는 기업 확인 필요합니다. 로그 로테이션 1MB/10개는 이상거래 탐지 임계값에 해당하지 않습니다.
55	블록체인 관련 사고나 장애가 있었다면 원인과 재발 방지 조치는 무엇입니까.	보안사고·블록체인 장애의 발생 여부, 원인과 재발 방지 기록은 기업 확인 필요합니다. 저장소에 사고 기록이 없다는 이유로 무사고로 답변하지 않습니다.

□ 10. 잔액 대조와 기존 점검

No.	질의 항목	회신
56	온체인 잔액과 내부 원장을 얼마나 자주 대조합니까. 누가 수행하고 누가 확인합니까.	정기 대사 주기와 수행·검토 직무는 미확인입니다. 잔액 조회는 가능하나 user 토큰

No.	질의 항목	회신
		필드는 수량 원장이 아니라 지금 상태 1입니다. 회수 시 차감/초기화도 없어 독립 원장 확인이 필요합니다.
57	대조 결과가 맞지 않은 적이 있습니까. 원인은 무엇이었습니까.	실제 대사 불일치 이력과 원인은 기업 확인 필요합니다. 구조상 온체인 성공 후 DB 실패·반복 전송·회수 미반영 시 상태 차이가 생길 수 있으나 실제 발생을 검증한 것은 아닙니다.
58	기존 감사에서 지적된 항목 중 조치하지 않은 것이 있습니까. 조치하지 않은 이유는 무엇입니까.	기존 감사 보고서·미조치 목록 및 사유는 기업 확인 필요합니다. 저장소 테스트 코드와 이번 기술 설명서는 외부 감사나 조치 완료 증적을 대체하지 않습니다.